CYBERSECURITY PORTFOLIO PROJECT

Small Business Threat Model

& Risk Assessment Report

Using STRIDE Threat Modelling Framework

Subject Organisation: Agra Textiles Pvt Ltd (Fictional Case Study)

Uday Sharma

Framework: STRIDE | Risk Matrix

Executive Summary

This report is a threat model and risk assessment I put together for Agra Textiles Pvt Ltd, a fictional 20-person garment export company based in Agra, Uttar Pradesh. The goal was to work through the full process mapping out what the business owns, figuring out where the real risks sit, and then translating that into controls and recommendations a small business could actually act on.

I identified twelve threats across six asset categories. Six of them came out as HIGH risk, mainly because of how common the attack types are and how much damage they'd cause if they landed. The biggest gaps are around ransomware exposure, phishing, and the fact that there's no MFA anywhere on the business. The good news is that most of these are fixable without significant spend.

Key Findings at a Glance

Security Area	Current Status
Multi-Factor Authentication (Email & Systems)	✕ Not Implemented
Office Macro Controls	✕ Not Implemented
Admin Privilege Restriction	✕ Not Implemented
Application Patching	◻ Partial Inconsistent
Offsite / Cloud Backup	◻ Partial No offsite copy
Ransomware Readiness	✕ Critical Gap
Browser Hardening	✕ Not Implemented
Operating System Patching	◻ Partial No central control

Section 1 Business Profile

Organisation Overview

Agra Textiles Pvt Ltd is a garment manufacturing and export company with around 20 people on staff. They deal with international buyers, manage supplier relationships across India, and handle the kind of data that makes them an attractive target financial records, customer PII, export contracts, and pricing information. Day to day, they're running on Microsoft 365, Tally ERP, and a fairly heavy reliance on WhatsApp for supplier communication.

Staff & Roles

Role	Count	Digital Access Level
Owner / Director	1	Email, Banking, ERP, Admin
Accounts / Finance	2	Tally ERP, Email, Banking Portal
Sales / Export Coordinators	6	Email, M365, WhatsApp Business
Warehouse / Production Staff	8	Shared workstations, limited access
IT (Informal / Part-time)	1	All systems, full local admin
Vendor / Supplier Contacts	External	Email, WhatsApp only

Digital Asset Register

Asset	Description	Data Handled	Sensitivity
Windows Laptops (×12)	Staff workstations running Windows 10/11 with Office 365	Business data, emails, documents	HIGH
NAS File Server	On-premise shared drive for orders, invoices, contracts	Financial records, contracts, PII	HIGH
Business Email (M365)	Primary communication with buyers and suppliers	PII, pricing, negotiation, contracts	HIGH
Tally ERP (Local)	Accounting and inventory software, installed locally	Financial records, GST data	HIGH
Company Website	WordPress site, externally hosted, used for buyer outreach	Public marketing content	MEDIUM
WhatsApp Business	Informal channel for supplier and buyer coordination	Order details, pricing, delivery info	MEDIUM
Internet Router / Modem	BSNL/Jio business broadband network gateway for all traffic	Network perimeter control	HIGH
USB Drives (×5)	Used informally for file transfers between workstations	Mixed unknown content	MEDIUM

Network Overview

The network is flat no segmentation, no VLAN separation between staff machines, the NAS, and guest traffic. The router is the only thing standing between the office and the internet, and it's running default settings. Remote

workers connect straight to M365 with no VPN in place. For a business handling export contracts and financial data, this is a pretty wide-open setup.

Section 2 Threat Register

Methodology: STRIDE Framework

I used STRIDE to structure the threat identification. It covers Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, and Elevation of Privilege. The reason I like STRIDE for this kind of assessment is that it stops you from only thinking about external attackers. It forces you to consider insider threats, data integrity failures, and availability risks, which are just as real for a business like this.

Each threat is rated on two axes: Likelihood (how probable is this given what's currently in place) and Impact (what happens to the business if it actually occurs). Risk is the combined read of both. I tried to keep the ratings grounded in what's realistic for an SMB of this size, not what would apply to a large enterprise.

ID	Threat	Asset	Threat Actor	Attack Scenario	Likelihood	Impact	Risk
T-01	**Phishing Email**	Email / Laptops	External Criminal Groups	Staff member clicks a malicious link in a spoofed supplier email, submitting M365 credentials to an attacker-controlled page.	**HIGH**	**HIGH**	**HIGH**
T-02	**Ransomware via Email Attachment**	Laptops / NAS Server	Ransomware Gangs	A malicious Excel or Word attachment executes a payload that encrypts the NAS and all connected workstations, halting operations.	**HIGH**	**HIGH**	**HIGH**
T-03	**Weak or Reused Passwords**	All Systems	Any Remote Attacker	Staff reuse personal passwords across work accounts. A breach of one service exposes M365, ERP, and banking portals.	**HIGH**	**HIGH**	**HIGH**
T-04	**No MFA on Business Email**	M365 Email	Remote Attackers	With only a password protecting email, a single phishing success gives full inbox access enabling Business Email Compromise (BEC) fraud.	**HIGH**	**HIGH**	**HIGH**
T-05	**Unpatched Third-Party Applications**	Laptops	Automated Exploit Scanners	Chrome, Adobe Reader, and other apps are not consistently patched. Known CVEs remain open and exploitable for months.	**MEDIUM**	**HIGH**	**HIGH**
T-06	**Insider Data Theft**	NAS / Email	Disgruntled Employee	A departing sales coordinator copies the full customer and supplier database to a personal USB drive or Google Drive before leaving.	**MEDIUM**	**HIGH**	**MEDIUM**
T-07	**WordPress Plugin Exploit**	Company Website	Script Kiddies / Bots	Outdated WordPress plugins are publicly known vulnerabilities. Automated bots exploit these to deface the site or inject SEO malware.	**HIGH**	**MEDIUM**	**MEDIUM**
T-08	**USB Malware Drop**	Laptops	Physical / Social Engineer	An employee finds and plugs in an unknown USB drive (intentionally dropped), which auto-executes malware when inserted.	**MEDIUM**	**MEDIUM**	**MEDIUM**

ID	Threat	Asset	Threat Actor	Attack Scenario	Likelihood	Impact	Risk
T-09	**No Offsite Backup**	NAS / All Data	Any Incident (Fire, Ransomware)	Backups exist only on a USB drive stored in the same office. A fire, flood, or ransomware attack would destroy both the original and backup simultaneously.	**HIGH**	**HIGH**	**HIGH**
T-10	**Macro-Based Malware (Excel/Word)**	Laptops	Phishing Actors	Macros are enabled by default. A supplier-impersonation email delivers an Excel file whose macro executes a reverse shell or downloader payload.	**HIGH**	**HIGH**	**HIGH**
T-11	**Router Default Credentials**	Network Infrastructure	Local / Remote Attacker	The office router has never had its admin password changed from the factory default. Compromise gives full control of all network traffic.	**LOW**	**HIGH**	**MEDIUM**
T-12	**Shadow IT Personal Cloud Storage**	Business Data	Employees (Unintentional)	Staff save work files to personal Google Drive or Dropbox for convenience. Sensitive contract and pricing data leaves company control with no audit trail.	**HIGH**	**MEDIUM**	**MEDIUM**

Section 3 Risk Priority Matrix

The matrix below maps all 12 threats against their Likelihood and Impact ratings. Anything sitting in the HIGH-HIGH zone (top right, red) needs to be addressed first. That's where the real exposure is. This kind of visual makes it easier to have a conversation with a business owner about where to focus, rather than handing them a list and hoping they read it in order.

	LOW Impact	MEDIUM Impact	HIGH Impact
HIGH Likelihood	T-07 WordPress Plugin Exploit	T-12 Shadow IT / Personal Cloud	**T-01 Phishing Email** **T-02 Ransomware** **T-03 Weak Passwords** **T-04 No MFA on Email** **T-09 No Offsite Backup** **T-10 Macro-Based Malware**
MEDIUM Likelihood	N/A	T-06 Insider Data Theft T-08 USB Malware Drop	T-05 Unpatched Applications
LOW Likelihood	N/A	T-11 Router Default Credentials	N/A

Risk Summary

Risk Level	Threat Count	Threats
□ HIGH	6	T-01, T-02, T-03, T-04, T-09, T-10
□ MEDIUM	5	T-05, T-06, T-07, T-08, T-11, T-12
□ LOW	0	,

Section 4 Security Controls Gap Analysis

Each control below is assessed against what's actually in place, where it needs to get to, what the gap is, and what I'd recommend doing about it. I've tried to keep the actions specific enough to be actionable: not just 'implement MFA' but how to do it and roughly how long it takes.

C-01 | Multi-Factor Authentication ✕Not Implemented

Current State: Microsoft 365 accounts are protected by password only. No MFA is enforced on any account, including the owner and finance staff who have access to banking portals.

Target State: MFA enforced on all M365 accounts, banking portals, and any internet-facing service. Authenticator app preferred over SMS.

Gap: A single phished or guessed password grants full email access. Business Email Compromise (BEC) is a direct, high-probability consequence.

Recommended Action: Enable Microsoft Authenticator via M365 Admin Portal under Security > MFA. Configure Conditional Access policies to require MFA from all locations. Estimated setup time: 30 minutes.

Cost: Free (included in M365 Business Basic+) **Effort:** Very Low 30 minutes **Threats Addressed:** T-01, T-03, T-04

C-02 | Disable Office Macros by Default ✕Not Implemented

Current State: Microsoft Office macros are enabled by default across all workstations. No policy restricts which files can run macros.

Target State: Macros disabled by default. Only digitally signed macros from trusted internal publishers are permitted to execute.

Gap: Any Excel or Word file sent via email can execute arbitrary code without user warning. This is the primary delivery mechanism for commodity malware.

Recommended Action: Via M365 Admin Portal or Group Policy: User Config > Admin Templates > Microsoft Excel > Trust Centre > Block macros from running in Office files from the internet. Apply to all Office applications.

Cost: Free **Effort:** Low 1 hour **Threats Addressed:** T-02, T-10

C-03 | Restrict Administrative Privileges ✕Not Implemented

Current State: The majority of staff workstations have local administrator rights. All software installations, system changes, and file access run at elevated privilege.

Target State: Standard user accounts for all daily work. Separate named administrator accounts used only for approved administrative tasks. No shared admin accounts.

Gap: Any malware that executes under a standard session automatically inherits admin-level access, enabling full system compromise, lateral movement to the NAS, and mass encryption.

Recommended Action: Create new standard user accounts for all staff. Strip admin rights from daily-use accounts via Local Users and Groups (lusrmgr.msc). Create a separate, named admin account for the IT contact used only when required.

Cost: Free **Effort:** Medium 1 day **Threats Addressed:** T-02, T-06, T-08

C-04 | Regular Offsite Backups ◻ Partial

Current State: Files are periodically backed up to a USB drive stored in the same office. No cloud or offsite copy exists. The backup has never been tested for restoration.

Target State: Daily automated backups to a cloud service. Monthly restore test. 3-2-1 rule: 3 copies, on 2 different media types, with 1 stored offsite.

Gap: The co-located USB backup would be encrypted alongside originals in a ransomware attack, or destroyed in a physical incident. An untested backup cannot be relied upon for recovery.

Recommended Action: Subscribe to Backblaze Business or enable Microsoft OneDrive Backup for all workstations. Configure automated daily backup schedules. Perform a test restore quarterly and document the result.

Cost: Low approx. Rs 600/month for cloud backup **Effort:** Low 2 hours setup **Threats Addressed:** T-02, T-09

C-05 | Patch Applications Consistently ◻ Partial

Current State: Windows Update is enabled but third-party applications (Chrome, Adobe Reader, Tally, WinRAR) are updated manually and infrequently. Staff routinely dismiss update prompts.

Target State: All applications patched within 14 days of release. Critical security patches applied within 48 hours. Centralised visibility into patch status across all machines.

Gap: Known CVEs in outdated browsers and PDF readers remain exploitable for months after patches are available. Automated exploit kits actively target these.

Recommended Action: Enable automatic updates for all browsers and Office applications. Use Patch My PC Home Advisor (free) for third-party application patching. Conduct a monthly 'patch check' review on all machines.

Cost: Free **Effort:** Low 4 hours initial setup **Threats Addressed:** T-05, T-07

C-06 | Harden User-Facing Applications ✕Not Implemented

Current State: Browsers run with default configurations. No extension policy, no script control, no safe browsing enforcement beyond browser defaults.

Target State: Browsers hardened: disable unnecessary plugins, restrict extensions to an approved list, enforce Google Safe Browsing, block access to known malicious categories.

Gap: Default browser configurations present unnecessary attack surface. Browser extensions are a common vector for credential theft and data exfiltration.

Recommended Action: Deploy Chrome policies via Group Policy: restrict extensions to an IT-approved list, enable Safe Browsing (Enhanced), disable Flash (end-of-life), and configure pop-up blocking. Remove Java Runtime if not required by any business application.

Cost: Free **Effort:** Low 2 hours **Threats Addressed:** T-05, T-07

C-07 | Patch Operating Systems ◻ Partial

Current State: Windows Update is enabled on most machines, but some devices run Windows 10 Home which lacks enterprise update management features. No central visibility into OS patch status.

Target State: All OS security patches applied within 14 days. Critical patches within 48 hours. Centralised patch status dashboard available to IT contact.

Gap: Without centralised control, individual machines may fall months behind. Windows 10 Home cannot be managed via Group Policy or WSUS, creating blind spots.

Recommended Action: Upgrade all machines to Windows 10/11 Pro (required for Group Policy). Enrol devices in Microsoft Intune (free for up to 10 devices) for centralised patch management and compliance reporting.

Cost: Free to Low (Intune), Pro upgrade licence cost if applicable **Effort:** Medium **Threats Addressed:** T-05

C-08 | Application Control (Allowlisting) ✗Not Implemented

Current State: No application whitelisting in place. Staff can install and run any executable from any source without restriction or approval.

Target State: Only approved, known-good applications permitted to execute on workstations. Unapproved executables blocked by default.

Gap: Malware delivered via phishing, USB, or drive-by download can execute freely. No technical control prevents an unknown executable from running.

Recommended Action: Deploy Windows Defender Application Control (WDAC), which is built into Windows 10/11 Pro and Enterprise at no cost. Create an approved application list. Enforce via Group Policy. Begin in audit mode to identify gaps before switching to enforcement.

Cost: Free built into Windows **Effort:** Medium-High 2 to 3 days including audit phase **Threats Addressed:** T-02, T-08, T-10

Section 5 Prioritised Recommendations

These are ordered by how much risk you take off the table relative to how much effort it takes. The quick wins at the top are there because a small business is more likely to actually do them, and doing something impactful quickly matters more than having a perfect 12-month roadmap that never gets started.

#	Action	Threats Mitigated	Cost	Effort	Expected Outcome
1	Enable MFA on all M365 accounts	T-01, T-03, T-04	Free	30 mins	Blocks 99%+ of automated account compromise attacks. Single highest-ROI action available.
2	Disable Office Macros by default	T-02, T-10	Free	1 hour	Eliminates the primary delivery mechanism for commodity ransomware and malware.
3	Remove admin rights from standard accounts	T-02, T-06, T-08	Free	1 day	Limits blast radius of any successful compromise. Prevents lateral movement and mass encryption.
4	Set up automated cloud backup	T-02, T-09	Rs 600/mo	2 hours	Makes ransomware recoverable. Protects against physical loss. Must include quarterly restore tests.
5	Enable application patching (auto-update all apps)	T-05, T-07	Free	4 hours	Closes known exploitable vulnerabilities in browsers and productivity software.
6	Harden browsers via Group Policy	T-05, T-07	Free	2 hours	Reduces browser-based attack surface. Restricts malicious extensions and enforces safe browsing.
7	Deploy Windows Defender Application Control	T-02, T-08, T-10	Free	2–3 days	Prevents unapproved executables from running. Highest technical effort but strongest preventive control.
8	Change router admin password from default	T-11	Free	15 mins	Closes a trivial but commonly exploited entry point. Simple hygiene action.
9	Create Shadow IT policy and approved tools list	T-12	Free	2 hours	Prevents uncontrolled data spread to personal cloud services. Requires staff communication.

Conclusion

Agra Textiles sits in a pretty common spot for Indian SMBs in the export space. They're digitally dependent but haven't had the time or budget to think seriously about security. That's not a criticism, it's just the reality for most businesses their size. The problem is that the threats targeting them don't care about that context.

What stood out to me doing this assessment is how many of the HIGH-rated threats can be addressed with zero spend. MFA alone would close off a huge chunk of the attack surface. Disabling macros takes an hour. These aren't complex engineering problems. They're configuration decisions that just haven't been made yet.

If I were advising this business, I'd push hard on getting MFA live in week one, then work through the privilege and backup gaps over the following month. Application control and the Shadow IT policy can follow once the immediate fires are dealt with. The goal isn't perfection. It's making the organisation meaningfully harder to compromise than it is today.